Sicherheits- & Datenschutz-Offenlegung, Abschlussbericht

TCL Smart Home Android (com.tcl.smarthome)

TCL Smart Home ist zu 45 Prozent eine Tuya/ThingClips-App mit TCL-Branding, EU-Heimdaten werden über Alexa-Sprachbefehle nach China geroutet, ByteDance-Hook-Frameworks und Tencent-WeChat-Login/-Push ergänzen die Kette chinesischer Drittanbieter, drei der ursprünglich adressierten Kontaktadressen gebounced, acht Nachrichten über 74 Tage vollständig unbeantwortet, 19 Tage nach Ablauf des Embargos

ÖFFENTLICHE OFFENLEGUNG, 17. OKTOBER 2026 — EMBARGO ERREICHT AM 28. SEPTEMBER 2026, SECHS BEFUNDE UNBEANTWORTET

Zielunternehmen	TCL Technology Group Corporation, Shenzhen, China (HKEX: 01070)
Package	com.tcl.smarthome
Analysierte Plattform	Android, statische Analyse der Produktions-APK (110.155 Smali-Klassen, davon 49.949 aus com.thingclips)
Erstmeldung (R1)	2026-06-30 (REF TCL-SMARTHOME-2026)
Offenlegungs-/Embargo-Datum	2026-09-28
Bericht veröffentlicht	2026-10-17
Gesamtschwere	CRITICAL
Befunde	6 (2 Critical, 3 High, 1 Medium)
Korrespondenz	8 Nachrichten über 74 Tage, 0 Antworten jeder Art; 3 Adressen gebounced (privacy@tcl.com, dpo@tcl.com, press@tcl.com), Korrespondenz ab 2026-07-17 fortgesetzt an privacy_dpo@tcl.com
CC Behörden	Österreichische Datenschutzbehörde (DSB) · Europäischer Datenschutzbeauftragter (EDPS) · Bundesbeauftragte für den Datenschutz (BfDI, BCC auf Erstmeldung)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Gegenstand & Betreiber-Kontext 5

3 Korrespondenz-Zusammenfassung 5

4 Findings 5

4.1 C1: Firebase/Google-API-Key hartcodiert, identisch für drei Rollen (Haupt-Key, Crash-Reporting, Maps) . . . 5

4.2 C2: TCL Smart Home = Tuya/ThingClips: EU-Heimdaten werden über qin.tuyacn.com nach China geroutet . . . 6

4.3 H1: ByteDance ShadowHook + ByteHook: TikTok-Mutterkonzern-Hook-Framework ohne erkennbaren Zweck . . . 6

4.4 H2: WeChat-Login (30 Klassen) + Tencent XGPush + chinesische OEM-Push-Services . . . 7

4.5 H3: Berechtigungs-Stack: Biometrie + doppelt deklarierte High-Sampling-Rate-Sensoren + voller Sensor-Stack . . . 7

4.6 H4: Alibaba FastJSON + Umeng Analytics: dritte Alibaba-Komponente neben Tuya . . . 8

5 Impact-Analyse (Impact Analysis) 8

6 Die vollständige Kette (The Complete Chain): Acht Nachrichten, drei tote Adressen, 74 Tage, null Antworten 9

7 Datenschutz — Artikel für Artikel (Data Protection) 9

8 Regulatorisches & rechtliches Umfeld (Regulatory) 10

9 Indicators of Compromise 10

10 Offenlegungs-Zeitlinie (Disclosure Timeline) & Ergebnis 11

11 Restrisiko & Empfehlungen (Residual Risk) 11

Executive Summary

TCL Smart Home ist die Smart-Home-Steuerungs-App der TCL Technology Group Corporation (Shenzhen, China, HKEX: 01070), eines global agierenden TV- und Smart-Home-Herstellers mit erheblichem EU-Marktanteil. Eine Root-Level-Analyse der Produktions-Android-App (com.tcl.smarthome, 110.155 Smali-Klassen) fand sechs Befunde, zwei CRITICAL, drei HIGH und einen MEDIUM.

Ein Firebase/Google-API-Key ist identisch für drei Rollen (Haupt-Key, Crash-Reporting, Maps) hartcodiert, ohne Zertifikat-Fingerprint-Bindung (C1). Der zweite und schwerwiegendste Befund: 49.949 der 110.155 Smali-Klassen, 45 Prozent des gesamten Codes, stammen aus com.thingclips — TCL Smart Home ist keine eigenständige Entwicklung, sondern eine Tuya-App mit TCL-Branding (ThingClips ist Tuyas umbenanntes SDK). Amazon-Alexa-Sprachbefehle für TCL-Geräte werden über qin.tuyacn.com geroutet, einen Server in China, ohne dokumentierte Art. 46 DSGVO-Schutzmaßnahme; Chinas National Intelligence Law Art. 7 und Art. 12 verpflichten Tuya zur Kooperation mit chinesischen Behörden (C2). ByteDance (TikToks Mutterkonzern) stellt mit ShadowHook und ByteHook ein Framework bereit, das jeden nativen System-Call abfangen kann, ohne erkennbaren deklarierten Zweck (H1). WeChat-Login (30 Klassen) und Tencent XGPush übermitteln Authentifizierungs- und Push-Daten europäischer Nutzer nach China (H2). Ein umfassender Berechtigungs-Stack (Biometrie, doppelt deklarierte High-Sampling-Rate-Sensoren, Kamera, Mikrofon, GPS, unbegrenzte Hintergrundaktivität) rundet das Bild ab (H3). Alibaba FastJSON und Umeng Analytics fügen eine dritte Alibaba-Komponente neben der Tuya-Backend-Anbindung hinzu (H4, MEDIUM).

RFI-IRFOS meldete diese Befunde am 30. Juni 2026 an privacy@tcl.com und dpo@tcl.com, CC press@tcl.com, die österreichische Datenschutzbehörde (DSB) und den EDPS, BCC die deutsche Bundesbeauftragte für den Datenschutz (BfDI), mit Embargo-Datum 28. September 2026. Alle drei direkt adressierten Kontaktadressen (privacy@tcl.com, dpo@tcl.com, press@tcl.com) wurden von postmaster@tcl.com als unzustellbar zurückgewiesen. Ab dem 17. Juli 2026 wurde die Korrespondenz an privacy_dpo@tcl.com fortgesetzt, ausdrücklich als korrigierte Adresse benannt. Über acht Nachrichten und 74 Tage hinweg wurde keine einzige Antwort jeder Art empfangen.

ID	Severity	Title
C1	CRITICAL	Firebase/Google-API-Key hartcodiert, identisch für drei Rollen (Haupt-Key, Crash-Reporting, Maps)
C2	CRITICAL	TCL Smart Home = Tuya/ThingClips: EU-Heimdaten werden über qin.tuyacn.com nach China geroutet
H1	HIGH	ByteDance ShadowHook + ByteHook: TikTok-Mutterkonzern-Hook-Framework ohne erkennbaren Zweck
H2	HIGH	WeChat-Login (30 Klassen) + Tencent XGPush + chinesische OEM-Push-Services
H3	HIGH	Berechtigungs-Stack: Biometrie + doppelt deklarierte High-Sampling-Rate-Sensoren + voller Sensor-Stack
H4	MEDIUM	Alibaba FastJSON + Umeng Analytics: dritte Alibaba-Komponente neben Tuya

Gegenstand & Betreiber-Kontext

TCL Technology Group ist einer der größten TV- und Unterhaltungselektronik-Hersteller weltweit mit erheblichem EU-Marktanteil. Die Smart-Home-Sparte, Gegenstand dieses Berichts, ist strukturell nicht TCL-eigene Software: 45 Prozent des Codes stammen aus Tuya Inc. (Hangzhou, China), einem Smart-Home-Plattform-Anbieter, dessen SDK nach NYSE-Listing-Kontroversen unter dem Namen ThingClips weitergeführt wird. Diese OEM-Beziehung ist der strukturelle Ausgangspunkt für die C2-Befunde dieses Berichts.

Korrespondenz-Zusammenfassung

RFI-IRFOS sendete die Erstmeldung am 30. Juni 2026 an privacy@tcl.com und dpo@tcl.com, CC press@tcl.com, die österreichische DSB und den EDPS, BCC die deutsche BfDI, mit Embargo-Datum 28. September 2026 unter REF TCL-SMARTHOME-2026. Alle drei direkt adressierten Kontaktadressen (privacy@tcl.com, dpo@tcl.com, press@tcl.com) wurden umgehend von postmaster@tcl.com als unzustellbar zurückgewiesen. Eine Folgenachricht wurde am 6. Juli 2026 erneut an privacy@tcl.com und dpo@tcl.com gesendet, diesmal ohne registrierten Bounce. Ab dem 17. Juli 2026 wurde die Korrespondenz an privacy_dpo@tcl.com fortgesetzt, im Betreff ausdrücklich als die korrekte Adresse benannt; weitere Folgenachrichten gingen am 27. Juli, 15. August, 24. August, 31. August und 12. September 2026, jeweils CC die österreichische DSB und den EDPS. Über acht Nachrichten insgesamt wurde zu keinem Zeitpunkt eine Antwort jeder Art empfangen, auch keine automatische Bestätigung.

Findings

C1: Firebase/Google-API-Key hartcodiert, identisch für drei Rollen (Haupt-Key, Crash-Reporting, Maps)

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 8.0

```
firebase_database_url:          [REDACTED IN PUBLIC REPORT -- disclosed privately to
    TCL in R1]
google_api_key:                 [REDACTED IN PUBLIC REPORT -- disclosed privately to
    TCL in R1]
google_crash_reporting_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to
    TCL in R1] (identisch mit google_api_key)
google_maps_key:                [REDACTED IN PUBLIC REPORT -- disclosed privately to
    TCL in R1] (identisch mit google_api_key)
Zertifikat-Fingerprint-Bindung: keine
```

Impact: RFI-IRFOS blast-radius escalation: von HIGH/8.0 auf CRITICAL angehoben, weil ein einziger geleakter Key gleichzeitig drei Infrastruktur-Rollen (Haupt-API, Crash-Reporting, Maps) für TCLs globale Smart-Home-Installationsbasis kompromittiert, statt wie üblich nur eine. firebase_database_url, google_api_key, google_crash_reporting_api_key und google_maps_key sind in res/values/strings.xml hartcodiert und tragen denselben Wert,

ohne Zertifikat-Fingerprint-Bindung. Dies bildet eine Quota-DoS-Angriffsfläche gegen das Firebase-Projekt.

C2: TCL Smart Home = Tuya/ThingClips: EU-Heimdaten werden über qin.tuyacn.com nach China geroutet

---

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:H/SI:N/SA:N, 9.1

```
com.thingclips Smali-Klassen: 49.949 von 110.155 gesamt (45 %)
Alexa-Integration: https://qin.tuyacn.com/app-voice/en/534/alexaSkill/...
Geräte-Aktivierung: https://smartapp.tuya.com/s/p?p=%s&v=1.0
Support-E-Mail (hartcodiert): support@tuya.com

Art. 46 DSGVO Schutzmaßnahme für diesen Transfer: keine dokumentiert
```

Impact: 49.949 der 110.155 Smali-Klassen (45 % des gesamten Codes) stammen aus com.thingclips und bilden das vollständige Backend von TCL Smart Home: Device-Management, Cloud-Sync, Automatisierungsregeln, Nutzerprofil. TCL Smart Home ist damit keine eigenständige Entwicklung, sondern eine Tuya-App mit TCL-Branding; ThingClips ist Tuyas umbenanntes SDK nach den NYSE-Listing-Kontroversen. Amazon-Alexa-Sprachbefehle für TCL-Geräte werden über qin.tuyacn.com geroutet, einen Server in China; die Geräte-Aktivierung läuft über smartapp.tuya.com. Chinas National Intelligence Law Art. 7 und Art. 12 verpflichten Tuya zur Kooperation mit chinesischen Behörden auf Anforderung. Für den resultierenden Drittlandtransfer von EU-Heimdaten ist keine Art. 46 DSGVO-Schutzmaßnahme (Standardvertragsklauseln, Angemessenheitsbeschluss) dokumentiert.

H1: ByteDance ShadowHook + ByteHook: TikTok-Mutterkonzern-Hook-Framework ohne erkennbaren Zweck

---

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 7.1

```
com.bytedance.shadowhook -- native function interception framework
com.bytedance.android.bytehook -- ELF-Hooking-Library
Gesamt ByteDance-Klassen: 16
Dokumentierter Verarbeitungszweck: keiner
```

Impact: com.bytedance.shadowhook und com.bytedance.android.bytehook (16 Klassen insgesamt) stammen von ByteDance, dem Mutterkonzern von TikTok. ShadowHook ermöglicht das Abfangen jedes nativen System-Calls zur Laufzeit; ByteHook ist das darunterliegende ELF-Hooking-Framework. Für eine Smart-Home-App für Haushaltsgeräte ist kein spezifischer, dokumentierter Verarbeitungszweck für diese native Hook-Infrastruktur erkennbar; für deklarierte Zwecke wie Crash-Reporting existieren spezifischere, weniger invasive Bibliotheken.

H2: WeChat-Login (30 Klassen) + Tencent XGPush + chinesische OEM-Push-Services

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:L/SI:N/SA:N, 7.8

```
WeChat (com.tencent.mm) Login: 30 Klassen
xg_access_key (Tencent XGPush): vorhanden
mi_app_key, oppo_app_key, meizu_app_key, vivo_app_key: vorhanden
qqAppKey, wxAppKey: konfigurierbare Felder
```

Impact: WeChat-Social-Login (com.tencent.mm, 30 Klassen) übermittelt Authentifizierungsdaten europäischer Nutzer an Tencent. XGPush (Tencents Push-Notification-Service) bedeutet, dass Push-Benachrichtigungen für EU-Nutzer über Tencent-Server in China laufen. Weitere OEM-Push-Schlüsselfelder (mi_app_key, oppo_app_key, meizu_app_key, vivo_app_key) sowie konfigurierbare qqAppKey/wxAppKey-Felder sind vorhanden. Tencent wird in der Datenschutzerklärung möglicherweise nicht ausreichend als Auftragsverarbeiter für diesen Drittlandtransfer ausgewiesen.

H3: Berechtigungs-Stack: Biometrie + doppelt deklarierte High-Sampling-Rate-Sensoren + voller Sensor-Stack

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 7.6

```
USE_BIOMETRIC, USE_FINGERPRINT
HIGH_SAMPLING_RATE_SENSORS (2x deklariert)
CAMERA, RECORD_AUDIO
ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION
BLUETOOTH, BLUETOOTH_ADMIN, BLUETOOTH_SCAN, BLUETOOTH_CONNECT, BLUETOOTH_ADVERTISE
REQUEST_IGNORE_BATTERY_OPTIMIZATIONS, SCHEDULE_EXACT_ALARM
READ_EXTERNAL_STORAGE / WRITE_EXTERNAL_STORAGE, MODIFY_AUDIO_SETTINGS
```

Impact: HIGH_SAMPLING_RATE_SENSORS ist doppelt deklariert und erlaubt Sensor-Sampling über 200 Hz. Kombiniert mit RECORD_AUDIO, CAMERA, ACCESS_FINE_LOCATION/ACCESS_COARSE_LOCATION, der vollständigen Bluetooth-Berechtigungskette und USE_BIOMETRIC/USE_FINGERPRINT entsteht eine umfassende Umgebungs- und Personenerfassung. REQUEST_IGNORE_BATTERY_OPTIMIZATIONS ermöglicht unbegrenzte Hintergrundaktivität.

H4: Alibaba FastJSON + Umeng Analytics: dritte Alibaba-Komponente neben Tuya

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.2

```
com.alibaba.fastjson -- JSON-Serialisierer
com.thingclips.stencil.component.umeng -- Umeng Analytics (Alibaba)
```

Impact: com.alibaba.fastjson (Alibabas JSON-Serialisierer) und com.thingclips.stencil.component.umeng (Umeng Analytics, eine Alibaba-Analyseplattform) sind integriert. Kombiniert mit dem Tuya/ThingClips-Backend (das selbst auf Alibaba Cloud läuft) werden Nutzerdaten aus EU-Haushalten über drei Alibaba/Tuya-Komponenten verarbeitet, ohne dass dies in der Datenschutzerklärung transparent gemacht wird.

Impact-Analyse (Impact Analysis)

C2 ist der schwerwiegendste Befund dieses Berichts, nicht weil ein einzelner Fehler vorliegt, sondern weil er die Produktarchitektur selbst betrifft: TCL Smart Home ist zu 45 Prozent Tuya-Code, und Alexa-Sprachbefehle für Haushaltsgeräte europäischer Nutzer werden über chinesische Server geroutet, in einer Rechtsordnung, die Unternehmen zur Kooperation mit Nachrichtendiensten verpflichten kann. C1 verstärkt dieses Bild durch eine einfache, aber folgenreiche Nachlässigkeit: ein einziger Key deckt drei Infrastruktur-Rollen ab. H1 und H2 fügen zwei weitere chinesische Drittanbieter-Ketten hinzu (ByteDance, Tencent), H3 einen übermäßig breiten Berechtigungs-Stack, H4 eine dritte Alibaba-Komponente. Zusammen zeichnen die sechs Befunde das Bild eines Produkts, dessen EU-Endnutzer-Oberfläche TCL-Branding trägt, dessen tatsächliche Datenverarbeitung aber überwiegend über chinesische Cloud- und SDK-Anbieter läuft, ohne dass diese Kette in der Datenschutzerklärung nachvollziehbar wird.

Drei der vier ursprünglich adressierten Kontaktpunkte waren beim ersten Zustellversuch bereits tot; über acht Nachrichten und 74 Tage an die anschließend korrigierte Adresse wurde dennoch keine einzige Antwort jeder Art empfangen.

Die vollständige Kette (The Complete Chain): Acht Nachrichten, drei tote Adressen, 74 Tage, null Antworten

Schritt 1 — Meldung gesendet, dreifacher Bounce: RFI-IRFOS sendet den vollständigen Befundbericht am 30. Juni 2026 an privacy@tcl.com und dpo@tcl.com, CC press@tcl.com, österreichische DSB, EDPS, BCC die deutsche BfDI. Alle drei direkt adressierten Kontaktadressen (privacy@tcl.com, dpo@tcl.com, press@tcl.com) werden umgehend von postmaster@tcl.com als unzustellbar zurückgewiesen.

Schritt 2 — Erneuter Versuch: Am 6. Juli 2026 wird eine Folgenachricht erneut an privacy@tcl.com und dpo@tcl.com gesendet, diesmal ohne registrierten Bounce.

Schritt 3 — Adresskorrektur: Ab dem 17. Juli 2026 wird die Korrespondenz an privacy_dpo@tcl.com fortgesetzt, im Betreff ausdrücklich als korrekte Adresse benannt, CC durchgehend österreichische DSB und EDPS.

Schritt 4 bis 7 — Vier weitere Folgenachrichten: Am 27. Juli, 15. August, 24. August und 31. August 2026 sendet RFI-IRFOS weitere Nachrichten, jede mit den drei wiederholten Fragen. Keine davon wird beantwortet.

Schritt 8 — Letzte Folgenachricht: Am 12. September 2026, 74 Tage nach der Erstmeldung, stellt RFI-IRFOS fest, dass über sechs zugestellte Nachrichten an die korrigierte Adresse keine Antwort jeder Art empfangen wurde. Auch diese Nachricht bleibt unbeantwortet.

Schritt 9 — Embargo erreicht und überschritten: Das am 30. Juni 2026 einmalig genannte Embargo-Datum verstreicht am 28. September 2026, alle sechs Befunde unbeantwortet.

Schritt 10 — Veröffentlichung: Dieser Bericht erscheint 19 Tage nach dem Embargo-Datum. Über 109 Tage und acht Nachrichten, davon drei an zunächst tote Adressen, enthält die Korrespondenz null Antworten jeder Art.

Datenschutz — Artikel für Artikel (Data Protection)

Art. 32(1)(b) DSGVO — Sicherheit der Verarbeitung: C1s identischer Key für drei Infrastruktur-Rollen ohne Zertifikat-Fingerprint-Bindung.

Art. 44-49, Art. 13 DSGVO — Drittlandtransfer, Transparenz: C2s Tuya/ThingClips-Backend routet EU-Heimdaten und Alexa-Sprachbefehle nach China ohne dokumentierte Art. 46-Schutzmaßnahme.

Art. 5(1)(c), Art. 13 DSGVO — Datenminimierung, Transparenz: H1s ByteDance-Hook-Framework hat keinen dokumentierten Zweck.

Art. 44-49, Art. 13 DSGVO — Drittlandtransfer, Transparenz: H2s WeChat-Login und Tencent XGPush übermitteln Authentifizierungs- und Push-Daten nach China.

Art. 5(1)(c), Art. 9, Art. 25 DSGVO — Datenminimierung, Sonderkategorien, Privacy by Design: H3s umfassender Berechtigungs-Stack übersteigt die Erforderlichkeit und berührt potenziell biometrische Daten.

Art. 13 DSGVO — Transparenz: H4s Alibaba-Komponenten sind nicht als Subverarbeiter ausgewiesen.

Regulatorisches & rechtliches Umfeld (Regulatory)

TCL Technology Group Corporation (HKEX: 01070) ist ein global agierender TV- und Smart-Home-Hersteller mit erheblichem EU-Marktanteil. Die österreichische Datenschutzbehörde (DSB) und der Europäische Datenschutzbeauftragte (EDPS) wurden über die ursprüngliche Meldung und jede Folgenachricht informiert, die deutsche Bundesbeauftragte für den Datenschutz (BfDI) über die Erstmeldung (DSGVO Art. 83(2)(b)).

Bußgeldrahmen nach DSGVO: Art. 83(5) ist auf den Drittlandtransfer in C2 anwendbar, bis zu 20.000.000 € oder 4 % des weltweiten Jahresumsatzes. Art. 83(4) ist auf C1, H1, H2, H3 und H4 anwendbar, bis zu 10.000.000 € oder 2 % des weltweiten Jahresumsatzes. Dass drei von vier ursprünglich adressierten Kontaktpunkten eines Unternehmens dieser Größenordnung bereits beim ersten Zustellversuch nicht erreichbar waren, und dass auch die anschließend korrigierte Adresse über 74 Tage keine einzige Antwort produzierte, ist ein Faktum, das eine Aufsichtsbehörde neben den sechs technischen Befunden mit abwägen dürfte.

Indicators of Compromise

Die folgenden Identifikatoren, SDK-Pakete und Manifest-Deklarationen wurden ausschließlich durch statische Analyse der Produktions-APK extrahiert. Es wurden keine TCL-, Tuya-, ByteDance- oder Tencent-Server, -Konten oder -Infrastruktur geprüft.

```
C1 -- firebase_database_url, google_api_key, google_crash_reporting_api_key,
    google_maps_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to TCL in R1]

C2 -- com.thingclips/* (49.949 Klassen, 45% des Codes)
   qin.tuyacn.com (Alexa-Integration), smartapp.tuya.com (Geräte-Aktivierung)

H1 -- com.bytedance.shadowhook, com.bytedance.android.bytehook (16 Klassen)

H2 -- com.tencent.mm WeChat Login (30 Klassen), xg_access_key (Tencent XGPush)
   mi_app_key, oppo_app_key, meizu_app_key, vivo_app_key

H3 -- USE_BIOMETRIC, HIGH_SAMPLING_RATE_SENSORS (2x), CAMERA, RECORD_AUDIO,
   ACCESS_FINE_LOCATION, voller BLUETOOTH-Stack, REQUEST_IGNORE_BATTERY_OPTIMIZATIONS

H4 -- com.alibaba.fastjson, com.thingclips.stencil.component.umeng
```

Offenlegungs-Zeitlinie (Disclosure Timeline) & Ergebnis

2026-06-30 Erstmeldung an privacy@tcl.com und dpo@tcl.com, CC press@tcl.com, österreichische DSB, EDPS, BCC deutsche BfDI. Embargo: 2026-09-28. REF TCL-SMARTHOME-2026. Alle drei direkt adressierten Kontaktadressen bounced.

2026-07-06 Folgenachricht erneut an privacy@tcl.com/dpo@tcl.com, kein Bounce registriert.

2026-07-17 Korrespondenz fortgesetzt an privacy_dpo@tcl.com, ausdrücklich als korrekte Adresse benannt. CC österreichische DSB, EDPS.

2026-07-27, 2026-08-15, 2026-08-24, 2026-08-31 Vier weitere Folgenachrichten an privacy_dpo@tcl.com. Keine Antwort jeder Art, an keinem Punkt.

2026-09-12 Letzte Folgenachricht, 74 Tage seit der Erstmeldung. Keine Antwort folgt.

2026-09-28 Embargo-Datum erreicht, wie am 2026-06-30 einmalig genannt und nie revidiert. Korrespondenz-Stand: acht RFI-IRFOS-Nachrichten, null Antworten jeder Art, drei Adressen dauerhaft tot.

2026-10-17 Dieser Bericht veröffentlicht, 19 Tage nach dem Embargo-Datum.

Restrisiko & Empfehlungen (Residual Risk)

C1 — Sofort: identischen Key für alle drei Rollen rotieren und durch rollenspezifische, zertifikatsgebundene Keys ersetzen.

C2 — Sofort: eine Art. 46 DSGVO-Schutzmaßnahme (Standardvertragsklauseln oder Angemessenheitsbeschluss) für den Transfer von EU-Heimdaten über Tuya/ThingClips nach China dokumentieren, oder die Alexa-Sprachbefehlskette von EU-Nutzern auf eine EU-/EWR-Region umrouten.

H1 — Kurzfristig: den konkreten Verarbeitungszweck von ShadowHook/ByteHook dokumentieren und nach Art. 13 DSGVO offenlegen, oder entfernen, falls ungenutzt.

H2 — Kurzfristig: Tencent als Art. 28 DSGVO-Auftragsverarbeiter für WeChat-Login und XGPush in der Datenschutzerklärung ausweisen.

H3 — Kurzfristig: den Berechtigungs-Stack auf die tatsächlich genutzten Funktionen reduzieren, insbesondere Biometrie- und hochfrequente Sensor-Zugriffe.

H4 — Kurzfristig: Alibaba FastJSON und Umeng Analytics als Subverarbeiter nach Art. 13 DSGVO ausweisen.

Alle Befunde — die primären Kontaktadressen privacy@tcl.com und dpo@tcl.com instand setzen oder dauerhaft auf die funktionierende Adresse privacy_dpo@tcl.com umleiten: drei von vier ursprünglich adressierten Kontaktpunkten bereits beim ersten Versuch tot ist ein eigenständiger Prozessfehler, unabhängig von den sechs technischen Befunden dieses Berichts.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria Alle Befunde beruhen auf statischer Analyse der veröffentlichten Anwendung mittels öffentlich verfügbarer Werkzeuge. Es wurden keine TCL-, Tuya-,

ByteDance- oder Tencent-Server, -Konten oder -Infrastruktur geprüft. Technische Nachweise sind unter Chain of Custody archiviert und werden Aufsichtsbehörden auf Anfrage zur Verfügung gestellt. Forschung durchgeführt gemäß ISO/IEC 29147, der Freiheit der Wissenschaft (Art. 17 StGG) und DS-GVO Art. 89. REF TCL-SMARTHOME-2026.